

TỔNG HỢP PHÂN TÍCH NGHIỆP VỤ

BRAVO

THÔNG TIN TÀI LIỆU

Mẫu số : BM.90.02.1

Số : MB2023

Nội dung : Tính năng xác thực hai yếu tố (2 Factor Authentication)

Mục lục

I. Giới thiệu chung.....	4
1. Yêu cầu.....	4
2. Mục đích.....	4
3. Đối tượng sử dụng.....	4
4. Các tài liệu tham khảo	4
5. Các ký hiệu được sử dụng trong tài liệu.....	4
6. Thuật ngữ và định nghĩa.....	4
II. Cơ sở phân tích.....	5
1. Định nghĩa, khái niệm	5
2. Mục đích.....	5
III. Quy trình xử lý trên phần mềm.....	11
IV. Mô tả chi tiết chức năng và giao diện.....	13
1. Khai báo, lựa chọn loại xác thực	13
2. Xác thực qua các ứng dụng 2FA	16
3. Xác thực qua SMS/Email	26

LỊCH SỬ THAY ĐỔI TÀI LIỆU

Stt	Ngày	M/S/X ⁽¹⁾	Mục đích	Nhân sự sửa đổi
1	01/12/2023	M	Tạo mới	Đào Duy Minh

Chú thích:

⁽¹⁾ M – Mới; S – Sửa; X - Xóa

I. Giới thiệu chung

1. Yêu cầu

Mô tả quy trình, đưa ra giao diện tính năng Xác thực hai yếu tố (2FA)

2. Mục đích

- Tài liệu nghiên cứu nghiệp vụ và đưa ra phạm vi xử lý trên WinApp, WebApp, MobileApp cho phiên bản **Bravo8R4**.
- Tài liệu mô tả quy trình xử lý xác thực hai yếu tố

3. Đối tượng sử dụng

- Cán bộ phân tích nghiệp vụ: Phân tích nghiệp vụ, đưa ra giải pháp về nghiệp vụ.
- Cán bộ phát triển sản phẩm, Công nghệ: Căn cứ, phối kết hợp đưa ra giải pháp kỹ thuật.
- Cán bộ kiểm thử sản phẩm: Tham chiếu đưa ra tiêu chuẩn chấp nhận sản phẩm.
- Cán bộ kỹ thuật triển khai, kinh doanh, tư vấn,...: Nắm bắt nghiệp vụ, cơ sở ứng dụng, giải pháp phần mềm.

4. Các tài liệu tham khảo

5. Các ký hiệu được sử dụng trong tài liệu

Ký hiệu	Giải thích

6. Thuật ngữ và định nghĩa

Thuật ngữ/Từ viết tắt	Loại	Giải thích
<i>User</i>	Viết tắt/Thuật ngữ	<i>Người sử dụng</i>

II. Cơ sở phân tích

1. Định nghĩa, khái niệm

- **Xác thực 2FA (Two-Factor Authentication)** là một cơ chế bảo mật trong đó người dùng cần cung cấp hai dạng thông tin xác thực khác nhau để có thể truy cập vào tài khoản của mình. Thông thường, hai yếu tố này bao gồm:
 - + Yếu tố kiến thức (Knowledge Factor): Đây là thông tin mà người dùng biết, chẳng hạn như mật khẩu, mã PIN hoặc câu trả lời bí mật.
 - + Yếu tố sở hữu (Possession Factor): Đây là thông tin mà người dùng có, thường là một thiết bị di động, thẻ thông minh hoặc mã token đặc biệt.
- Khi sử dụng 2FA, người dùng cần nhập mật khẩu (yếu tố kiến thức) và sau đó cung cấp thông tin từ yếu tố sở hữu, chẳng hạn như mã xác minh được gửi qua tin nhắn văn bản, ứng dụng xác minh hoặc token thay đổi mỗi khoảng thời gian nhất định.
- Phương pháp này tăng cường đáng kể độ an toàn bảo mật cho tài khoản, vì người tấn công cần phải có cả thông tin mật khẩu và thiết bị hoặc thông tin sở hữu của người dùng mới có thể truy cập được vào tài khoản.
- **Ứng dụng 2FA** là một loại ứng dụng được sử dụng để tạo và quản lý các mã xác thực cho việc xác thực hai yếu tố. Cụ thể, ứng dụng này tạo ra mã số hoặc mã QR code đặc biệt cho từng tài khoản hoặc dịch vụ mà người dùng muốn bảo vệ.
 - + Khi kích hoạt 2FA cho tài khoản trên một trang web hoặc ứng dụng, thường sẽ được yêu cầu quét mã QR hoặc nhập mã số đặc biệt được tạo bởi ứng dụng 2FA. Khi đăng nhập vào tài khoản đó sau khi 2FA được kích hoạt, sẽ không chỉ cần mật khẩu mà còn cần nhập mã xác thực mới được tạo ra bởi ứng dụng 2FA.
 - + Các ứng dụng 2FA như Google Authenticator, Authy, Microsoft Authenticator và Duo Mobile đều cung cấp chức năng này, giúp tăng cường bảo mật cho tài khoản trực tuyến của bạn bằng cách yêu cầu một yếu tố xác thực bổ sung ngoài mật khẩu.

2. Mục đích

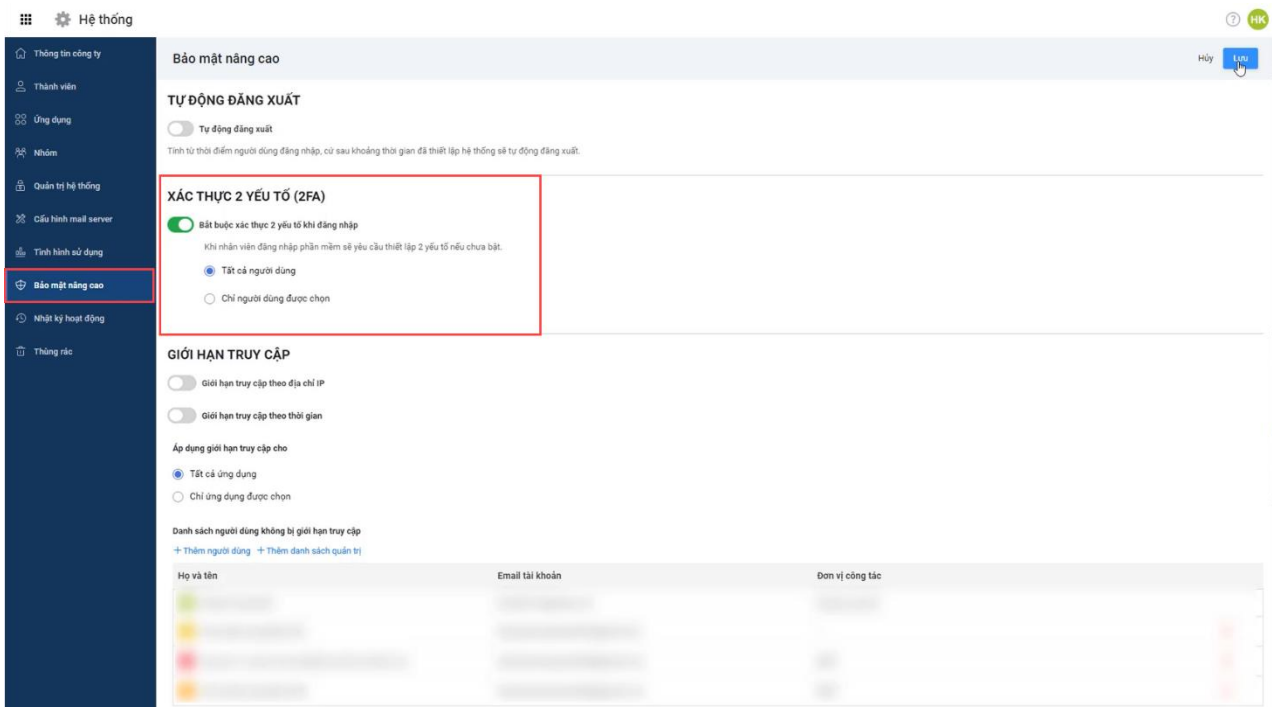
- Mục đích chính của xác thực hai yếu tố (2FA) là tăng cường bảo mật đối với tài khoản người dùng. Đây là một cơ chế bảo mật quan trọng trong việc đảm bảo rằng chỉ người dùng hợp lệ mới có thể truy cập vào thông tin cá nhân, dữ liệu quan trọng hoặc các dịch vụ trực tuyến.
- Các mục đích cụ thể của việc sử dụng xác thực 2FA bao gồm:
 - + Bảo vệ tài khoản: Ngăn chặn các cuộc tấn công truy cập trái phép vào tài khoản bằng cách yêu cầu một thông tin xác thực bổ sung ngoài mật khẩu.
 - + Ngăn chặn xâm nhập không được ủy quyền: Ngăn chặn việc truy cập bất hợp pháp vào tài khoản ngay cả khi người tấn công có mật khẩu bằng cách yêu cầu thông tin xác thực từ một nguồn hoặc thiết bị khác.
 - + Đối phó với việc phá hoại thông tin cá nhân: Bảo vệ thông tin cá nhân, dữ liệu quan trọng hoặc thông tin nhạy cảm khỏi việc truy cập trái phép hoặc việc sử dụng không đúng mục đích.
 - + Tăng cường an toàn khi giao dịch trực tuyến: Bảo vệ các giao dịch tài chính hoặc giao dịch trực tuyến bằng cách cung cấp một lớp bảo vệ bổ sung.

3. Khảo sát

a. MISA Amis

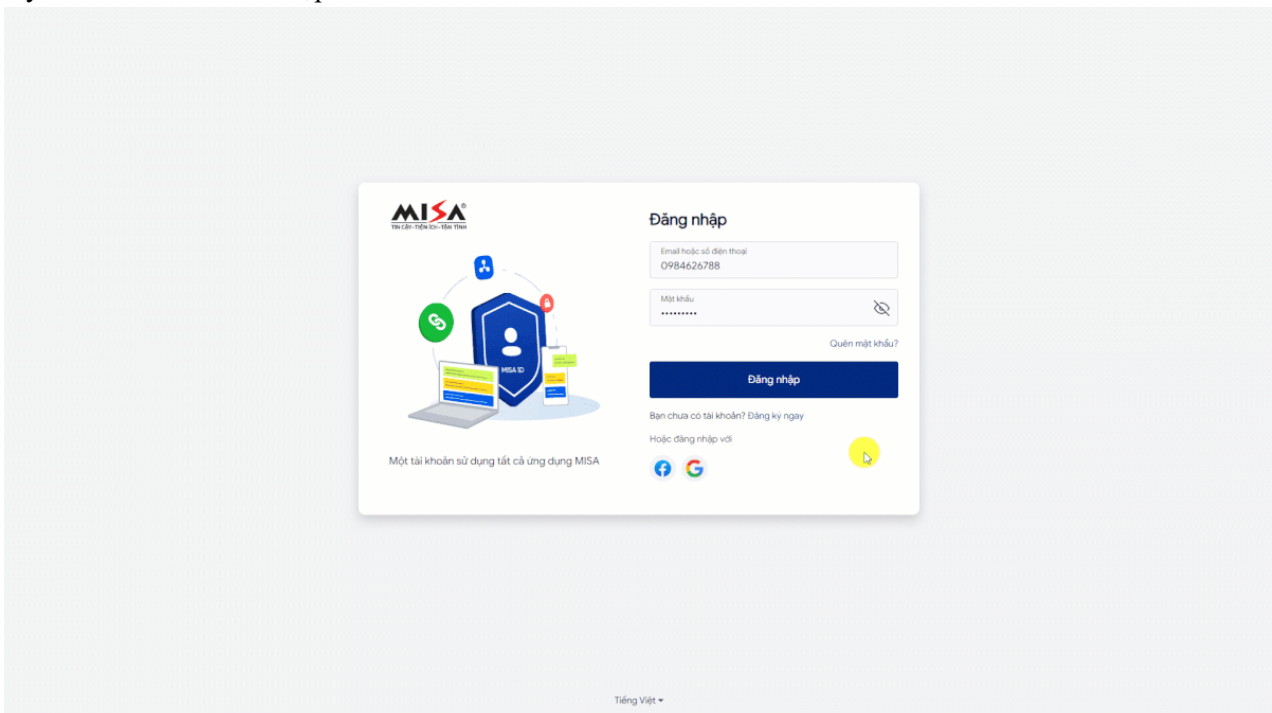
Cách 1: Quản trị hệ thống kích hoạt

Quản trị hệ thống mở ứng dụng AMIS Hệ thống, chọn phân hệ Bảo mật nâng cao. Nhấn “Chỉnh sửa” để bật chức năng xác thực 2 yếu tố 2FA.



Cách 2: Người dùng tự kích hoạt

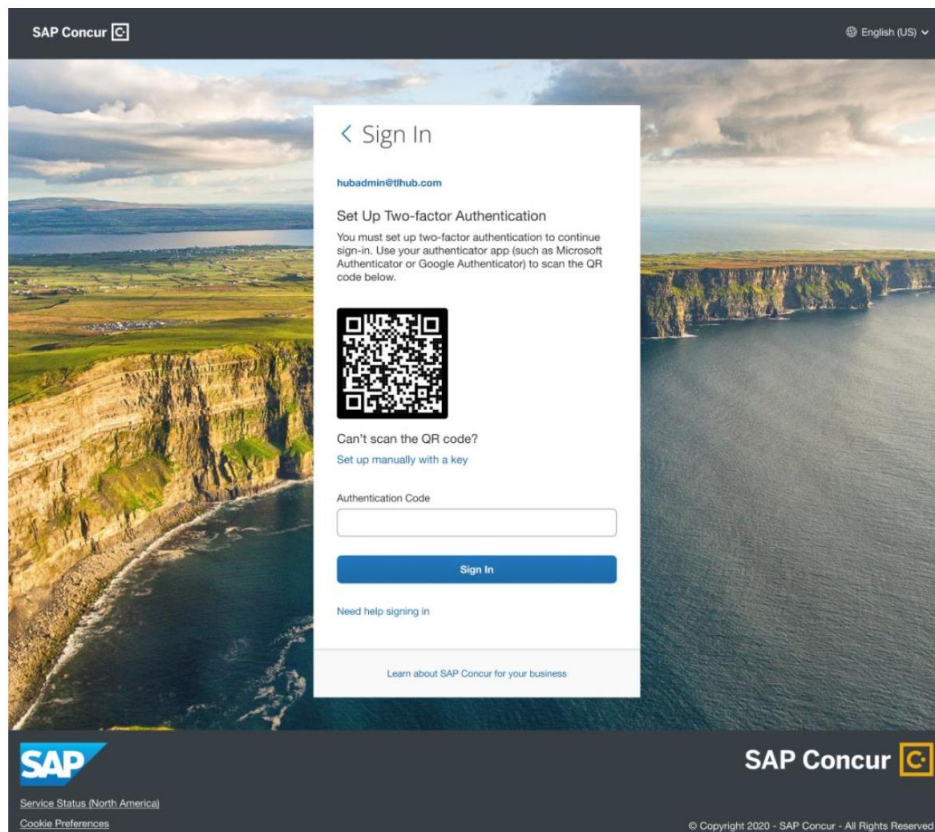
Người dùng đăng nhập vào tài khoản MISA ID > Chọn mục “Bảo vệ tài khoản” > Bật chức năng Xác thực 2 yếu tố và bắt đầu thiết lập.



b. SAP

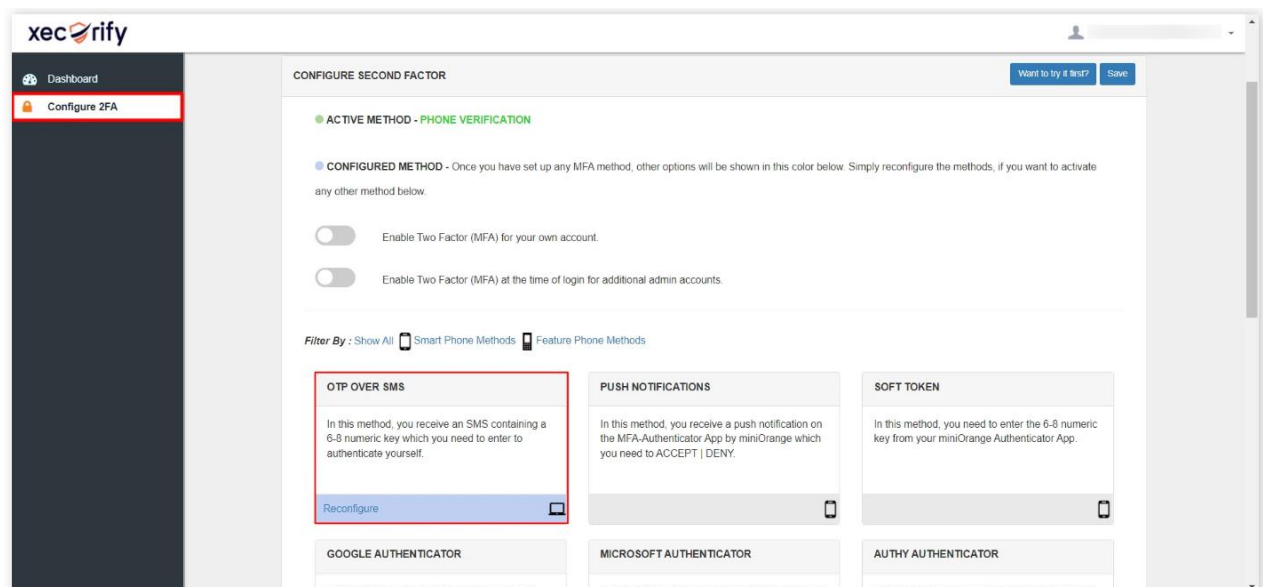


SAP-Concur-Two-Factor-Authentication-Setup



SAP chỉ hỗ trợ xác thực qua ứng dụng 2FA.

c. Oracle



Tính năng MFA trong Dịch vụ Đám mây Nhận dạng Oracle cho phép khách hàng thêm một bước bảo mật bổ sung vào quy trình xác thực. Có bốn yếu tố có thể xảy ra và một phương pháp sao lưu có thể được kích hoạt.

Câu hỏi bảo mật:

Người dùng được nhắc trong quá trình đăng nhập để trả lời chính xác một số câu hỏi bảo mật đã xác định nhằm xác minh danh tính của họ.

Ứng dụng xác thực di động:

Người dùng tạo OTP trên Ứng dụng OMA trên thiết bị của họ và phải được sử dụng trong quá trình đăng nhập.

Tin nhắn văn bản (SMS):

Người dùng nhận được mật mã tạm thời dưới dạng tin nhắn văn bản (SMS) trên thiết bị của họ. Mật mã này phải được sử dụng trong quá trình đăng nhập.

E-mail:

Người dùng nhận được thông báo email chứa mật mã tạm thời phải được sử dụng trong quá trình đăng nhập.

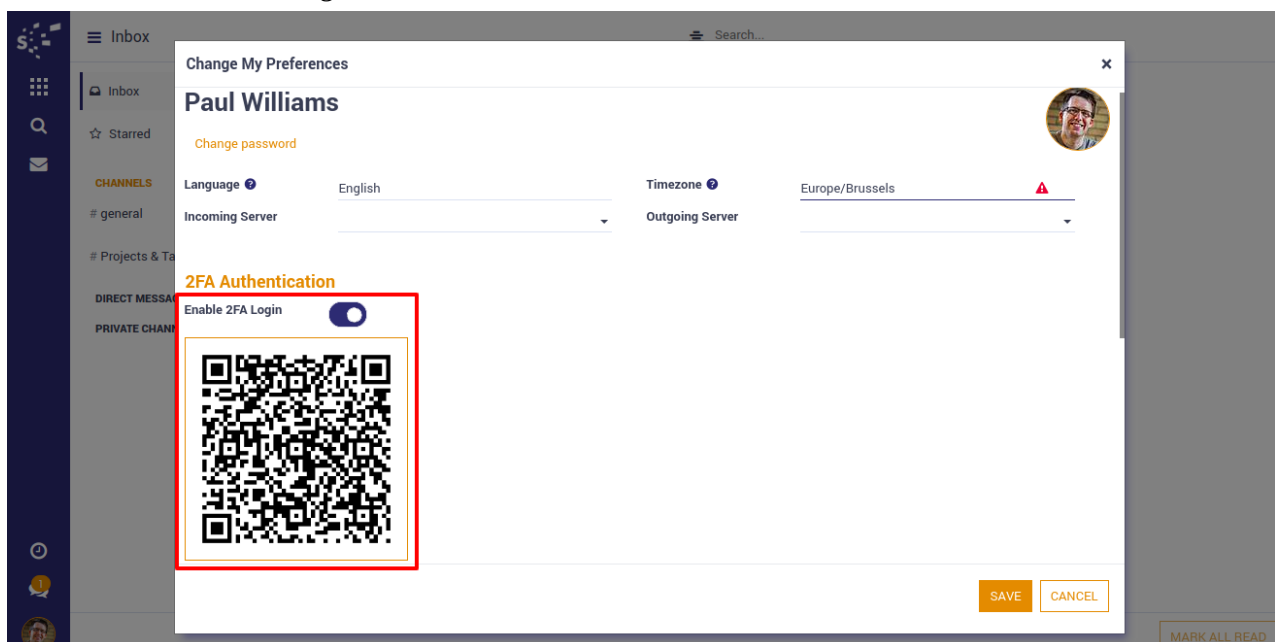
Mã bỏ qua:

Dịch vụ Đám mây Nhận dạng Oracle cũng cho phép người dùng tạo mã bỏ qua, mã này có thể được sử dụng làm phương pháp sao lưu khi người dùng quên câu trả lời cho các câu hỏi bảo mật, không có điện thoại di động hoặc không thể truy cập email của họ.

Link tham khảo: <https://docs.oracle.com/en/cloud/paas/identity-cloud/uaid/enable-multi-factor-authentication-security-oracle-cloud.html#GUID-964C1892-F41B-4268-A4CB-29922F25B65D>

d. Odo

User it self enable 2FA Login



Admin will enable 2FA Login

Two Factor Authentication Mail Sample

Dear Paul Williams,

Two factor authentication enabled for your account. below is your secret key and QR code. Do not share it with anyone.

Save this QR code or Secret key in safe place to further use.

Secret Key : ZTT73Z2FITC6TFC7



When user will login to the system using his Odoo credentials, system will ask for OTP.

To generate OTP first time user needs to scan QR code in Google authenticator App or option to receive OTP by mail. Enter the authentication code from authenticator app and click on 'Submit' button to proceed with login.

4. Thực trạng

- “Quản lý người sử dụng” đang quản lý các user áp dụng chung cho toàn bộ hệ thống, bao gồm cả WinApp, WebApp và MobileApp.
- Đối tượng sử dụng phần mềm đa dạng, có nhu cầu áp dụng những chính sách khác nhau, phù hợp với bản thân. Đặc biệt đối với những app thương hiệu thường sẽ có chân dung người dùng đa dạng.
- Việc sử dụng các phương thức xác thực bị giới hạn và hạn chế bởi các yếu tố khác như: chi phí, sự tiện dụng,... Ví dụ:
 - + Đối với phương thức xác thực qua SMS: phương thức này sẽ phụ thuộc vào nhà cung cấp dịch vụ (SMS Brandname), có thể xảy ra trục trặc, gián đoạn và phát sinh chi phí khá cao với một số lượng user lớn

- + Đối với phương thức xác thực qua Email và ứng dụng 2FA: đối với xác thực qua Email thì sẽ chủ yếu không phát sinh chi phí, tuy nhiên nếu sử dụng hệ thống mailchimp có thể phát sinh chi phí đi kèm. Ngoài ra hai phương thức này sẽ phù hợp đối với các đối tượng user trẻ, cập nhật công nghệ thông tin.

Hai hình thức khai báo áp dụng xác thực 2FA:

Hình thức	Điểm mạnh	Điểm yếu
<i>Thực hiện bởi quản trị viên hệ thống:</i> Quản trị viên hệ thống sẽ thiết lập user cần xác thực 2FA sau khi đăng nhập vào phần mềm và phương thức xác thực 2FA, user khi đăng nhập sẽ bắt buộc phải xác thực 2FA.	Độ bảo mật cao hơn. Giảm thiểu rủi ro an ninh mạng, đặc biệt đối với những tài khoản quan trọng hoặc có quyền truy cập đặc biệt.	Khó khăn cho người dùng, gây phiền toái đối với các đối tượng không có nhu cầu sử dụng. Người dùng từ chối sử dụng dịch vụ vì phức tạp và mất thời gian
<i>Thực hiện bởi người dùng:</i> Người dùng sẽ quyết định sử dụng 2FA hay không và phương thức xác thực thuận tiện nhất.	Tạo sự linh hoạt và thoải mái cho người dùng, có thể lựa chọn phương thức xác thực phù hợp nhất. Cải thiện trải nghiệm sử dụng dịch vụ	Độ bảo mật yếu hơn. Rủi ro cao hơn trong trường hợp tài khoản bị tấn công, bị hack.

- **Ví dụ:** Khi một khách hàng mua và sử dụng phần mềm BRAVO cho mục đích quản trị nội bộ và quản lý khách hàng. Lúc này sẽ có 2 nhóm user sử dụng phần mềm: **Nhóm A** (sẽ bao gồm các user là cán bộ, nhân viên của công ty) và **nhóm B** (bao gồm các user là khách hàng của công ty).
 - + Trong trường hợp này, quản trị hệ thống có thể yêu cầu bắt buộc nhóm A xác thực 2FA để đảm bảo tính bảo mật.
 - + Tuy nhiên, không thể áp dụng yêu cầu bắt buộc nhóm B xác thực 2FA vì điều này sẽ gây khó khăn trong trường hợp user không có nhu cầu sử dụng và có thể người dùng sẽ từ chối sử dụng vì phức tạp và mất thời gian.
- Trên thực tế, sau quá trình khảo sát các nhà cung cấp phần mềm hỗ trợ xác thực 2FA (Các đối thủ: Misa, Fast, SAP, Oracle,...) đều đang hỗ trợ người dùng tùy chọn các chế độ xác thực 2FA theo nhu cầu riêng của từng người dùng.
- Hiện tại trên phần mềm Bravo đang có 2 hình thức đăng nhập vào phần mềm:

Hình thức 1: Đối với khai báo tài khoản người sử dụng thủ công, cần hỗ trợ khai báo loại xác thực 2FA cho các trường hợp:

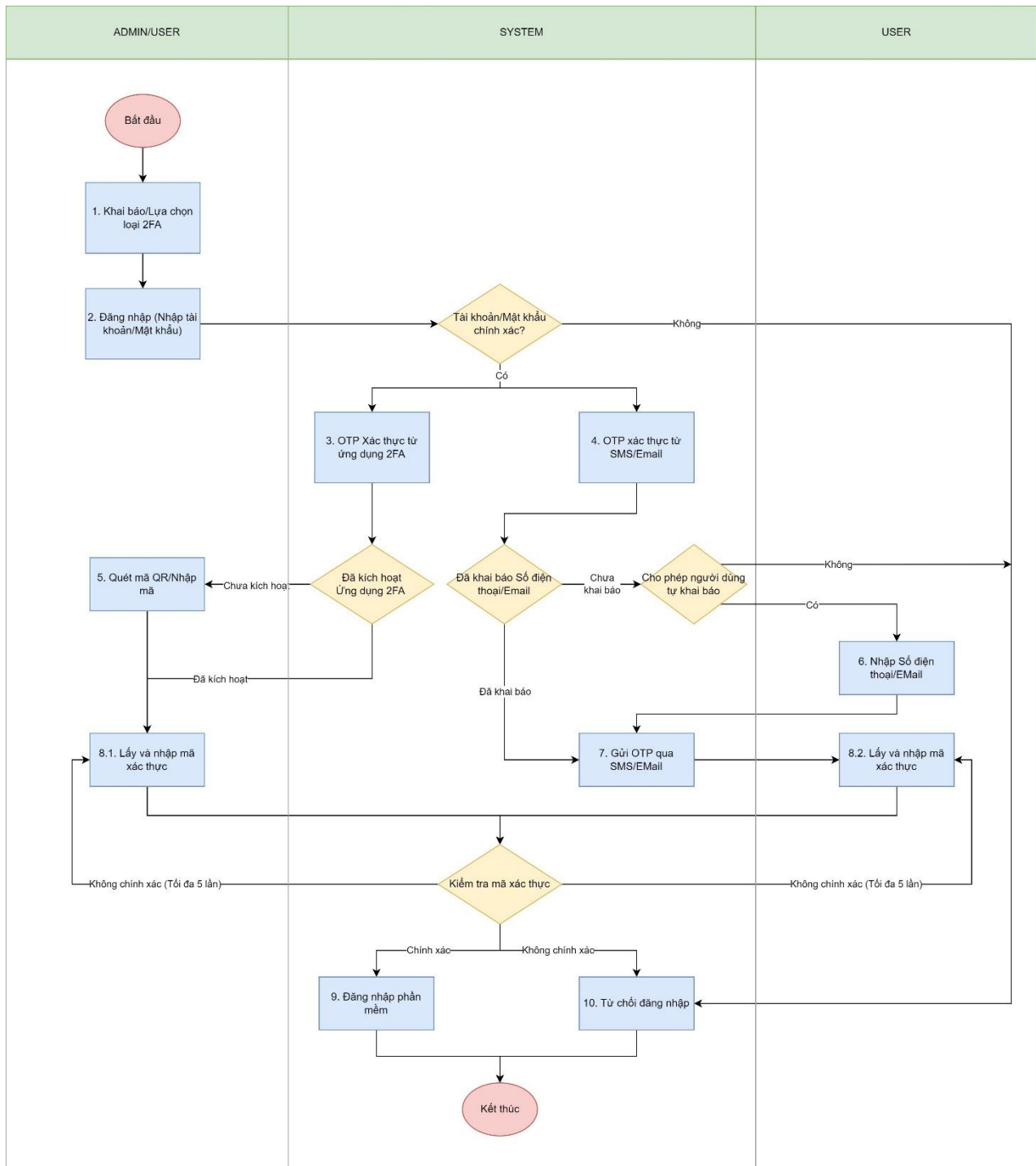
- + Khai báo cho toàn hệ thống
- + Khai báo cho một nhóm user
- + Khai báo cho từng user

Hình thức 2: Đối với các hình thức đăng nhập SSO, có 2 cơ chế đang áp dụng:

- + Gán tài khoản khi duyệt đăng nhập SSO → Trở về tương tự hình thức 1, quản trị hệ thống tạo user và gán cho tài khoản SSO tương ứng.
- + Tự động tạo tài khoản khi duyệt đăng nhập SSO → Cần hỗ trợ cơ chế khai báo loại xác thực cho các tài khoản được tạo tự động

III. Quy trình xử lý trên phần mềm

Quy trình:



Mô tả chi tiết:

Bước	Tên bước	Đối tượng thực hiện	Mô tả
1	Khai báo/ Lựa chọn loại 2FA	Quản trị hệ thống / Người dùng	Khai báo lựa chọn hình thức xác thực hai yếu tố tài khoản, bao gồm: + Xác thực qua ứng dụng 2FA

			+ Xác thực qua Email + Xác thực qua SMS + Không sử dụng 2FA Admin hệ thống có thể thiết lập hình thức xác thực hai yếu tố cho một nhóm tài khoản. Người dùng có thể thiết lập theo tài khoản cá nhân. Hình thức xác thực sẽ được ưu tiên theo thiết lập của nhóm tài khoản.
2	Đăng nhập	Người dùng	Người dùng tiến hành đăng nhập vào phần mềm
Hệ thống kiểm tra tài khoản/mật khẩu người dùng cung cấp: + Nếu chính xác thì chuyển sang bước 3 và 4 + Nếu không thì chuyển sang bước 10.			
3	OTP xác thực từ ứng dụng 2FA	Hệ thống	Nếu tài khoản lựa chọn xác thực qua ứng dụng 2FA, hệ thống hiển thị giao diện nhập mã xác thực tương ứng.
Hệ thống xác định tài khoản đã kích hoạt ứng dụng 2FA chưa: + Nếu chưa kích hoạt thì chuyển sang bước 5 + Nếu đã kích hoạt thì chuyển sang bước 8.1.			
4	OTP xác thực từ SMS/Email	Hệ thống	Nếu tài khoản lựa chọn xác thực qua SMS/Email, hệ thống hiển thị giao diện nhập mã xác thực tương ứng.
Hệ thống xác định tài khoản đã khai báo Số điện thoại/Email chưa và hệ thống có cho phép người dùng khai báo email/số điện thoại không: + Nếu chưa khai báo và cho phép người dùng khai báo thì chuyển sang bước 6 + Nếu chưa khai báo và KHÔNG cho phép người dùng khai báo thì chuyển sang bước 10. + Nếu đã khai báo thì chuyển sang bước 7.			
5	Quét mã QR /Nhập mã khóa thiết lập	Người dùng	Hệ thống hiển thị mã QR và Mã khóa thiết lập. Người dùng sử dụng các ứng dụng 2FA (Google/Microsoft Authenticator,...) để quét mã hoặc nhập Mã khóa thiết lập. Sau đó ứng dụng 2FA sẽ hiển thị mã xác thực bao gồm 6 chữ số.
6	Nhập số điện thoại/ Email	Người dùng	Người dùng nhập Số điện thoại hoặc Email xác thực.
7	Gửi OTP qua SMS/ Email	Hệ thống	Hệ thống gửi mã xác thực đến số điện thoại/Email người dùng đã khai báo
8.1 + 8.2	Lấy và nhập mã xác thực	Người dùng	Người dùng lấy mã xác thực từ ứng dụng 2FA/SMS/Email sau đó nhập trên phần mềm Bravo.
Hệ thống kiểm tra mã xác thực: + Nếu chính xác thì chuyển sang bước 9 + Người dùng có thể nhập mã xác thực tối đa 5 lần, nếu không chính xác có thể quay trở lại bước 8.1 + 8.2 để lấy lại mã xác thực. Nếu quá 5 lần không chính xác sẽ chuyển sang bước 10.			

9	Đăng nhập phần mềm	Hệ thống	Hệ thống tự động đăng nhập vào phần mềm
10	Từ chối đăng nhập	Hệ thống	Từ chối đăng nhập, quay lại màn hình Đăng nhập.

IV. Mô tả chi tiết chức năng và giao diện

1. Khai báo, lựa chọn loại xác thực

- Bổ sung khai báo hỗ trợ quản trị hệ thống lựa chọn:
 - + Có sử dụng 2FA hay không
 - + Các phương thức xác thực có thể sử dụng
 - + Các đối tượng bắt buộc sử dụng 2FA
- Đề áp dụng cho:

a. Toàn bộ user của hệ thống

- Tất cả các user đều phải sử dụng xác thực 2FA khi đăng nhập và sẽ lựa chọn một trong những phương thức xác thực có thể sử dụng.
- Quản trị viên hệ thống truy cập “Quản lý người sử dụng” và tiến hành thiết lập tại nhóm “Everyone”.
- Chi tiết giao diện như sau:

The screenshot displays the 'Cập nhật thông tin người sử dụng*' (Update user information*) window. The left sidebar shows the navigation menu with 'Nhóm người sử dụng' (User groups) selected. The main area is titled 'Thông tin chung nhóm' (Group general information) and shows the 'Mã' (Code) as 'Everyone' and 'Tên' (Name) as 'Tất cả' (All). Below this, the 'Xác thực hai yếu tố (2FA)' (Two-factor authentication) section is expanded, showing a toggle for 'Sử dụng xác thực hai yếu tố (2FA)' (Use two-factor authentication) which is currently turned off. Underneath, there is a list of roles: 'Vai trò người dùng' (User roles) with options 'Administrator', 'Database Designer', 'Layout Designer', and a button 'Thêm dữ liệu mới' (Add new data). At the bottom, there are buttons for 'Lưu và thêm mới' (Save and add new), 'Lưu và quay ra' (Save and return), 'Lưu tạm' (Save temporarily), and 'Hủy bỏ' (Cancel). The footer shows the date 'Thêm dữ liệu mới: 04/01/24 3:28 PM (MINHDD)' and the user 'Default'.

Thông tin được bổ sung:

Stt	Thông tin	Mô tả
1	Sử dụng xác thực hai yếu tố (2FA)	Quản trị viên hệ thống xác định toàn bộ user có sử dụng xác thực hai yếu tố 2FA không. Chỉ những user có role Administrator có quyền thay đổi thông tin này. Khi lựa chọn bật “Sử dụng xác thực hai yếu tố (2FA)”, chương trình sẽ hiển thị thêm “Phương thức xác thực”.
2	Phương thức xác thực	Lựa chọn phương thức xác thực có thể sử dụng. Người dùng có thể lựa chọn sử dụng một trong số phương thức xác thực này khi đăng nhập vào phần mềm. Bắt buộc lựa chọn ít nhất một phương thức, có thể lựa chọn nhiều. Bao gồm các lựa chọn: + 1: Ứng dụng Authenticator + 2: Email + 4: Sms

- **Yêu cầu bổ sung:** Tại màn hình Explorer Quản lý người sử dụng, bổ sung thêm trường thông tin “Xác thực hai yếu tố”, hiển thị tương tự thông tin “Khóa dữ liệu theo người dùng”.

b. Một nhóm user được chỉ định

- Tất cả các user thuộc nhóm được chỉ định đều phải xác thực 2FA khi đăng nhập và sẽ lựa chọn một trong những phương thức xác thực có thể sử dụng.
- Quản trị viên hệ thống truy cập “Quản lý người sử dụng” và tiến hành thiết lập tại các nhóm user.
- Giao diện và thao tác sẽ tương tự tại nhóm Everyone đã được mô tả phía trên.

c. Một user được chỉ định

- User được chỉ định đều phải xác thực 2FA khi đăng nhập và sẽ lựa chọn một trong những phương thức xác thực có thể sử dụng.
- Quản trị viên hệ thống truy cập “Quản lý người sử dụng” và tiến hành thiết lập cho từng user được chỉ định.
- Chi tiết giao diện như sau:

Cập nhật thông tin người sử dụng*

Layout1

1. Công cụ nhập liệu

Nhóm người sử dụng

Người sử dụng

Lấy danh sách kho

1. Người sử dụng CHANHBT

2. Tên đầy đủ Bùi Thị Chanh

3. Nhân viên CHANHBT: Bùi Thị Chanh

4. Khách hàng

5. Số điện thoại 0366171927

6. Email chanhbt@gmail.com

7. Nền tảng 4: Mobile

8. Khóa dữ liệu riêng cho người sử dụng

9. Khóa dữ liệu riêng theo người dùng

10. Ngày khóa dữ liệu

11. Mật khẩu truy cập

12. Mật khẩu cũ

13. Mật khẩu mới

14. Gõ lại mật khẩu mới

15. Vai trò người dùng

16. Administrator

17. Database Designer

18. Layout Designer

19. Thêm dữ liệu mới

20. Vai trò người dùng

21. Vai trò duyệt chứng tử

22. Danh sách kho người dùng được truy cập

23. Lưu và thêm mới

24. Lưu và quay ra

25. Lưu tạm

26. Hủy bỏ

Thêm dữ liệu mới: 04/01/24 3:28 PM (MINHDD)

Default Văn phòng Công ty Cổ phần BRAVO 2024 MINHDD 20

Cập nhật thông tin người sử dụng*

Layout1

1. Công cụ nhập liệu

Nhóm người sử dụng

Người sử dụng

Lấy danh sách kho

1. Người sử dụng CHANHBT

2. Tên đầy đủ Bùi Thị Chanh

3. Nhân viên CHANHBT: Bùi Thị Chanh

4. Khách hàng

5. Số điện thoại 0366171927

6. Email chanhbt@gmail.com

7. Nền tảng 4: Mobile

8. Khóa dữ liệu riêng cho người sử dụng

9. Khóa dữ liệu riêng theo người dùng

10. Ngày khóa dữ liệu

11. Mật khẩu truy cập

12. Mật khẩu cũ

13. Mật khẩu mới

14. Gõ lại mật khẩu mới

15. Vai trò người dùng

16. Administrator

17. Database Designer

18. Layout Designer

19. Thêm dữ liệu mới

20. Vai trò người dùng

21. Vai trò duyệt chứng tử

22. Danh sách kho người dùng được truy cập

23. Lưu và thêm mới

24. Lưu và quay ra

25. Lưu tạm

26. Hủy bỏ

27. Xác thực hai yếu tố (2FA)

28. Sử dụng xác thực hai yếu tố (2FA)

29. Phương thức xác thực

30. 7: 1,2,4

31. 1 Ứng dụng Authenticator

32. 2 Email

33. 4 SMS

Thêm dữ liệu mới: 04/01/24 3:28 PM (MINHDD)

Default Văn phòng Công ty Cổ phần BRAVO 2024 MINHDD 20

Thông tin được bổ sung:

Stt	Thông tin	Mô tả
1	Sử dụng xác thực hai yếu tố (2FA)	Quản trị viên hệ thống xác định user có sử dụng xác thực hai yếu tố 2FA không. Chỉ những user có role Administrator có quyền thay đổi thông tin này.

		Khi lựa chọn bật “Sử dụng xác thực hai yếu tố (2FA)”, chương trình sẽ hiển thị thêm “Phương thức xác thực”.
2	Phương thức xác thực	Lựa chọn phương thức xác thực có thể sử dụng. Người dùng có thể lựa chọn sử dụng một trong số phương thức xác thực này khi đăng nhập vào phần mềm. Bắt buộc lựa chọn ít nhất một phương thức, có thể lựa chọn nhiều. Bao gồm các lựa chọn: + 1: Ứng dụng Authenticator + 2: Email + 4: Sms Trong trường hợp lựa chọn xác thực qua Email hoặc SMS, hai thông tin Email và Số điện thoại trên màn hình sẽ hiển thị cảnh báo nhập liệu tương ứng. Có thể bỏ qua thông tin này để tiếp tục lưu.

d. Đối với các tài khoản được tạo tự động khi đăng nhập SSO

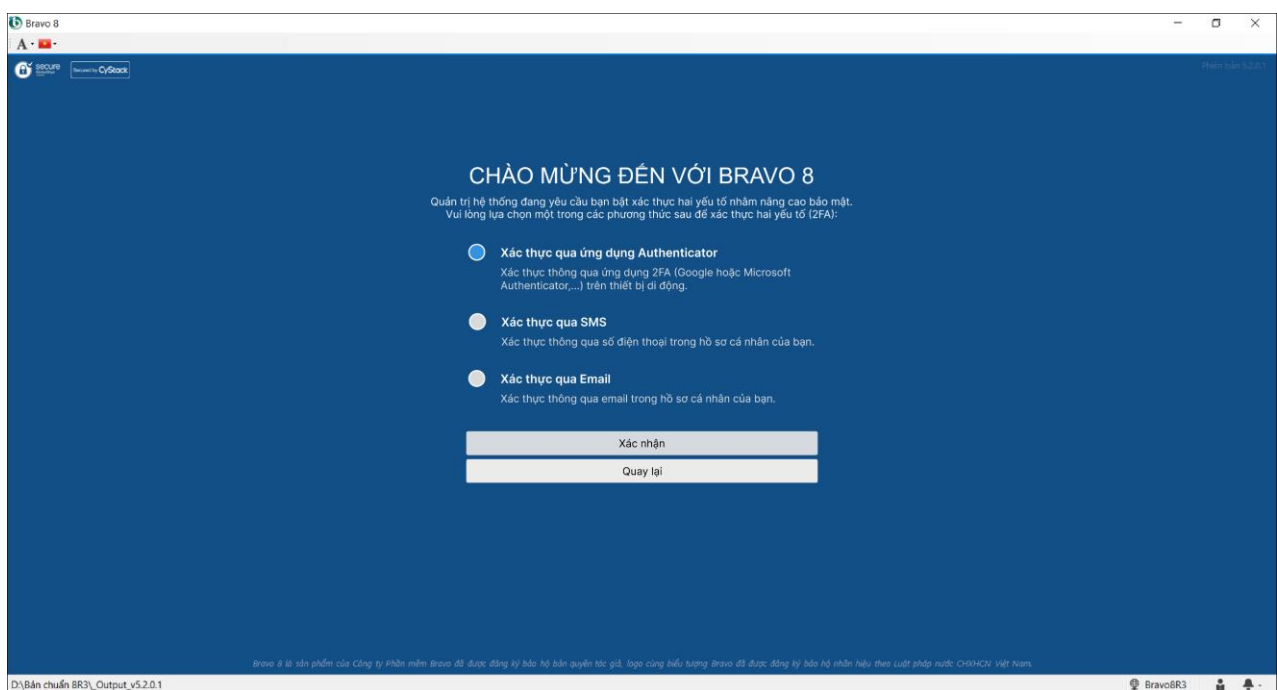
- Bổ sung cơ chế khai báo loại xác thực mặc định cho các tài khoản được tạo tự động khi đăng nhập SSO.

Lưu ý:

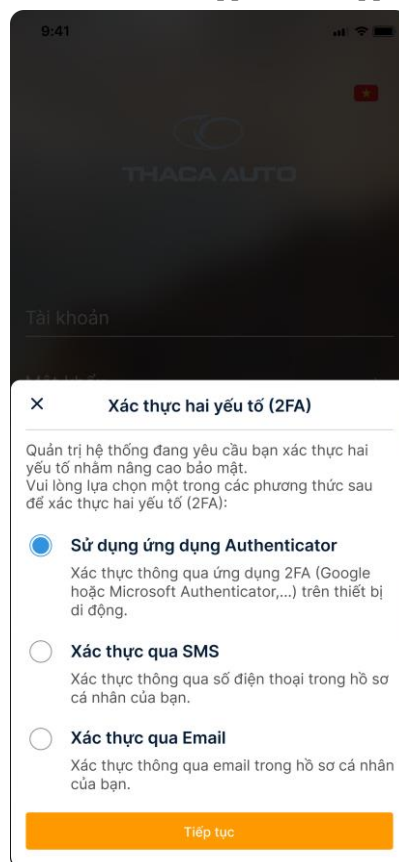
- + Không hỗ trợ khai báo trên MobileApp, chỉ hỗ trợ khai báo trên WinApp và WebApp.
- + Khi khai báo phương thức xác thực sẽ được áp dụng cho tất cả các nền tảng mà tài khoản có quyền truy cập để đảm bảo tính đồng nhất và bảo mật.
- + Mức độ ưu tiên: Người dùng > Nhóm người dùng (từ cấp thấp nhất đến cao nhất) > Everyone

2. Lựa chọn phương thức xác thực khi đăng nhập

- Trong lần đầu tiên user đăng nhập vào phần mềm sau khi bật chế độ xác thực hai yếu tố, chương trình sẽ xác định và hiển thị các phương thức xác thực khả dụng với user theo mức độ ưu tiên: Người dùng > Nhóm người dùng (từ cấp thấp nhất đến cao nhất) > Everyone.
- Người dùng có thể lựa chọn một trong những phương thức này để tiến hành xác thực.
- Chi tiết giao diện như sau:

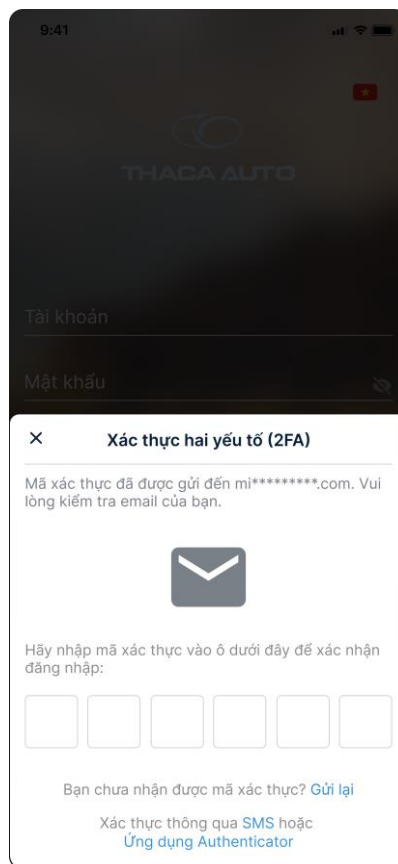
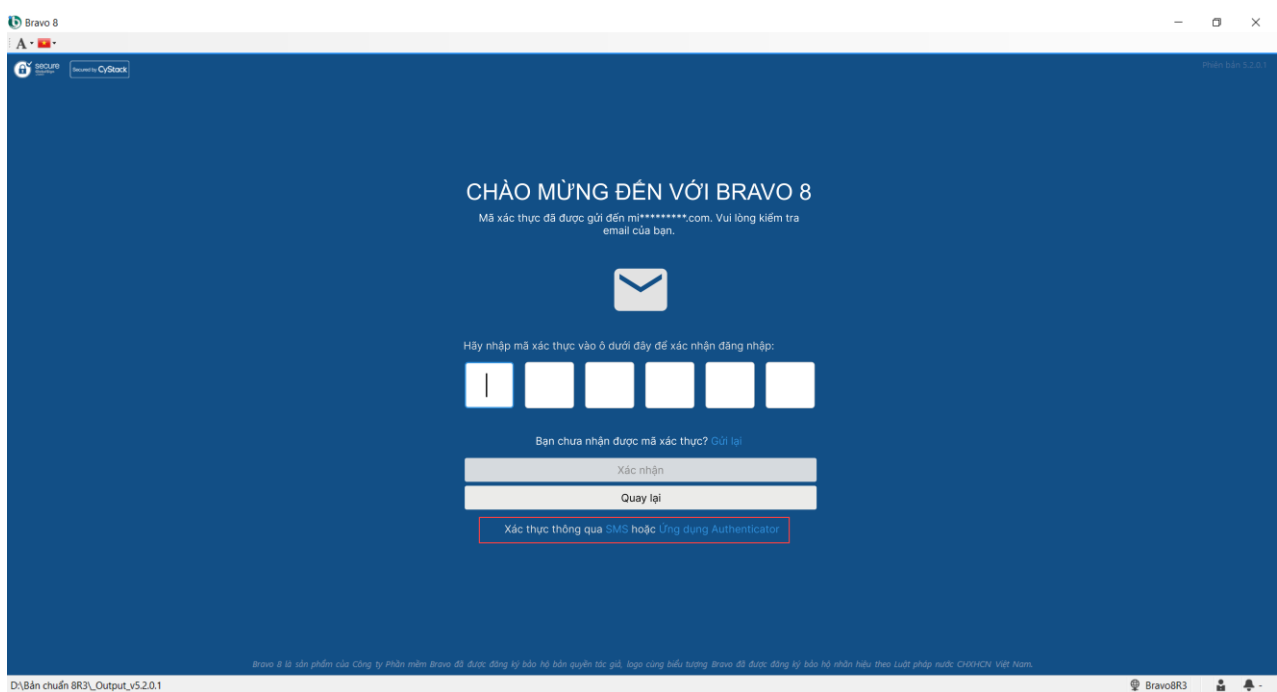


Giao diện WinApp và WebApp



Giao diện MobileApp

- Màn hình này chỉ hiển thị trong trường hợp có từ 2 phương thức xác thực trở lên. Nếu chỉ có 1 phương thức xác thực thì sẽ chuyển trực tiếp vào màn hình thực hiện xác thực.
- Sau lần đầu tiên xác thực thành công, từ những lần đăng nhập tiếp theo, chương trình sẽ ghi nhớ lần xác thực đăng nhập gần nhất và hiển thị cho người dùng.
- Ngoài ra người dùng cũng có thể thực hiện xác thực qua các phương thức khả dụng khác bằng cách lựa chọn các phương thức gợi ý ở phía dưới màn hình:

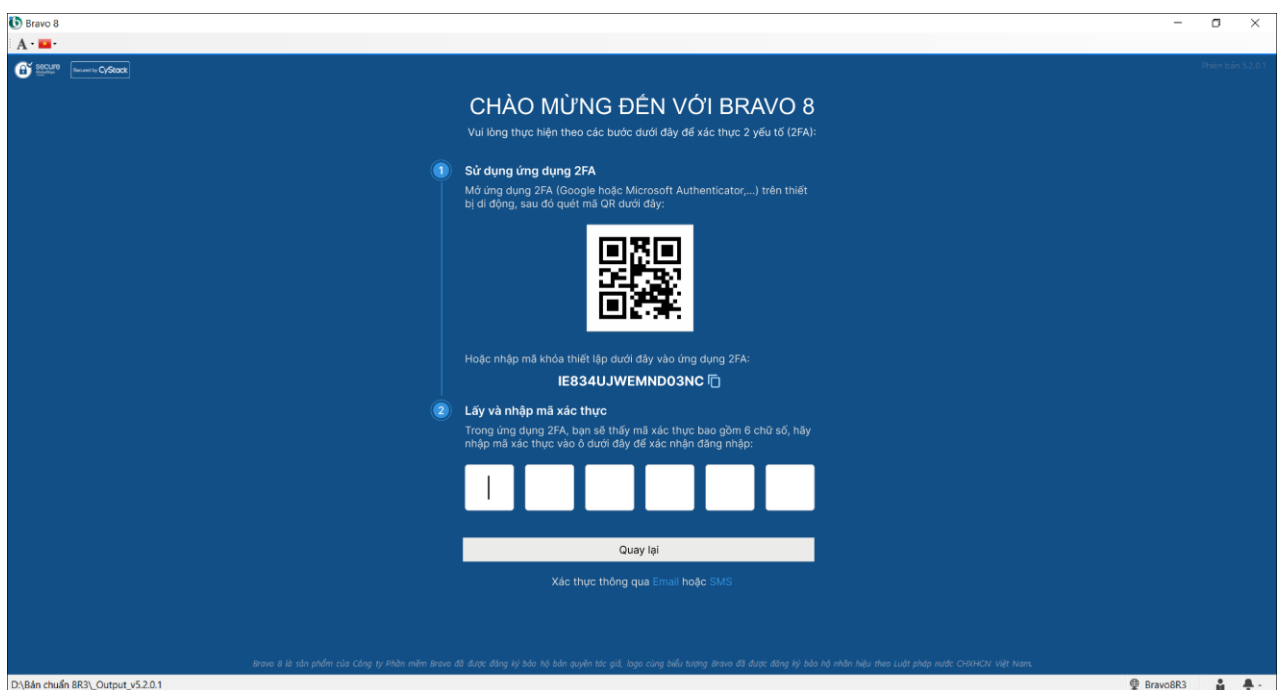


3. Xác thực qua các ứng dụng 2FA

Trong lần đầu đăng nhập có xác thực bằng ứng dụng 2FA, người dùng cần thực hiện xác thực với ứng dụng tương ứng.

Bước 1: Khi người dùng tiến hành đăng nhập trên phần mềm Bravo, hệ thống sẽ hiển thị mã QR và mã khóa thiết lập.

Có thể click chọn  để sao chép mã khóa thiết lập.

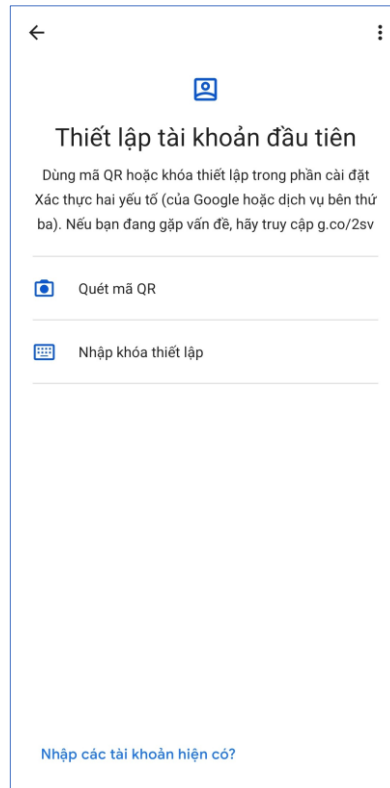


Giao diện WinApp/WebApp

Giao diện MobileApp	Đối với MobileApp, người dùng thường có nhu cầu nhập mã khóa thiết lập nhiều hơn Quét mã QR nên

	khi người dùng có nhu cầu quét mã QR sẽ lựa chọn thêm “Quét mã QR”, khi đó ứng dụng sẽ hiển thị mã QR. Có thể chọn “Lưu ảnh” để lưu mã này về thư viện. Khi lưu sẽ hiển thị thông báo Toast “Đã lưu vào thư viện hình ảnh”
--	---

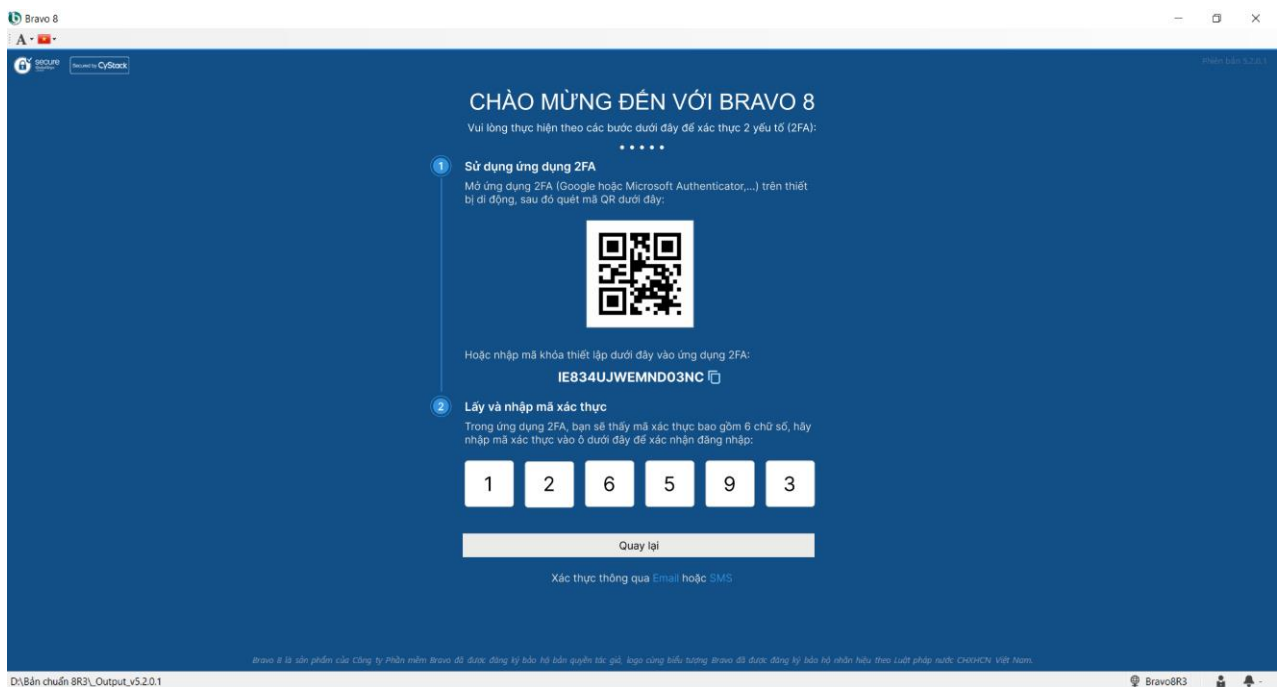
Bước 2: Người dùng sử dụng ứng dụng Authenticator quét mã QR hoặc nhập mã tương ứng. Ví dụ giao diện trên app Google Authenticator:



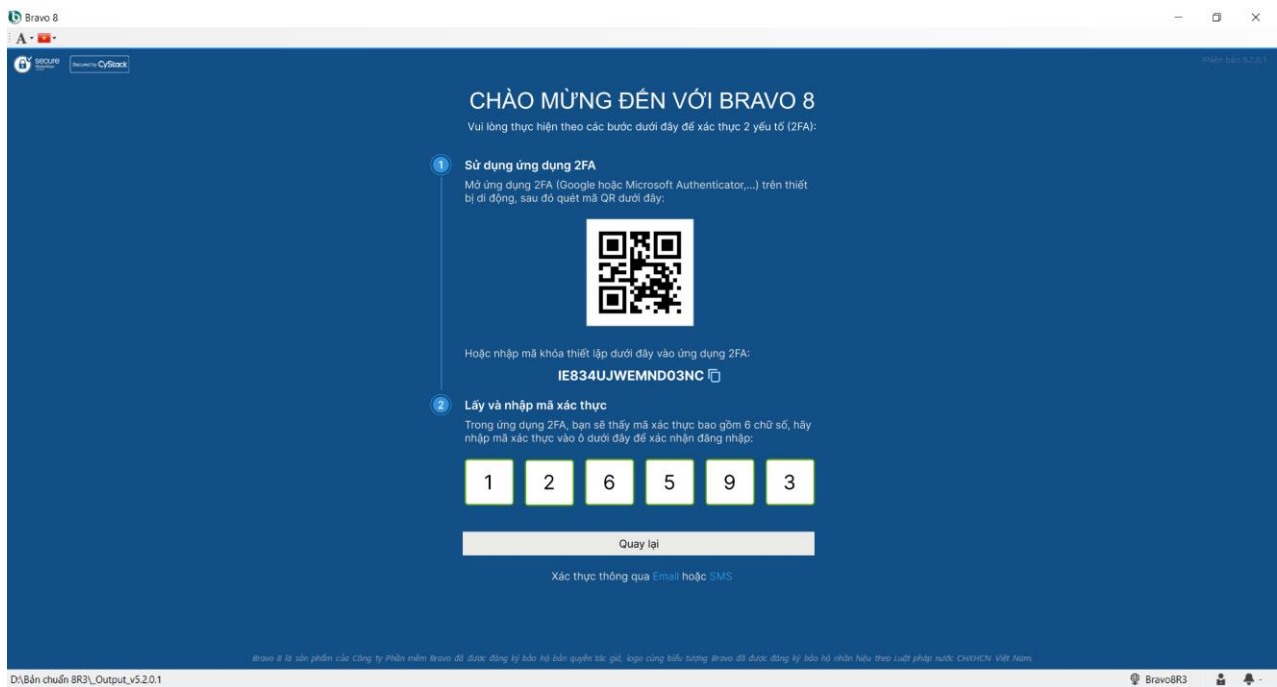
Bước 3: Sau khi đã xác thực ứng dụng 2FA thành công, Ứng dụng 2FA sẽ tự động sinh ra một mã xác thực (bao gồm 6 ký tự, không thể chỉnh sửa số lượng ký tự phần này). Các ứng dụng 2FA như Google Authenticator, Authy, Microsoft Authenticator và Duo Mobile. Mã này sẽ được thay đổi tự động theo một khoảng thời gian nhất định, tùy theo cơ chế của ứng dụng 2FA.



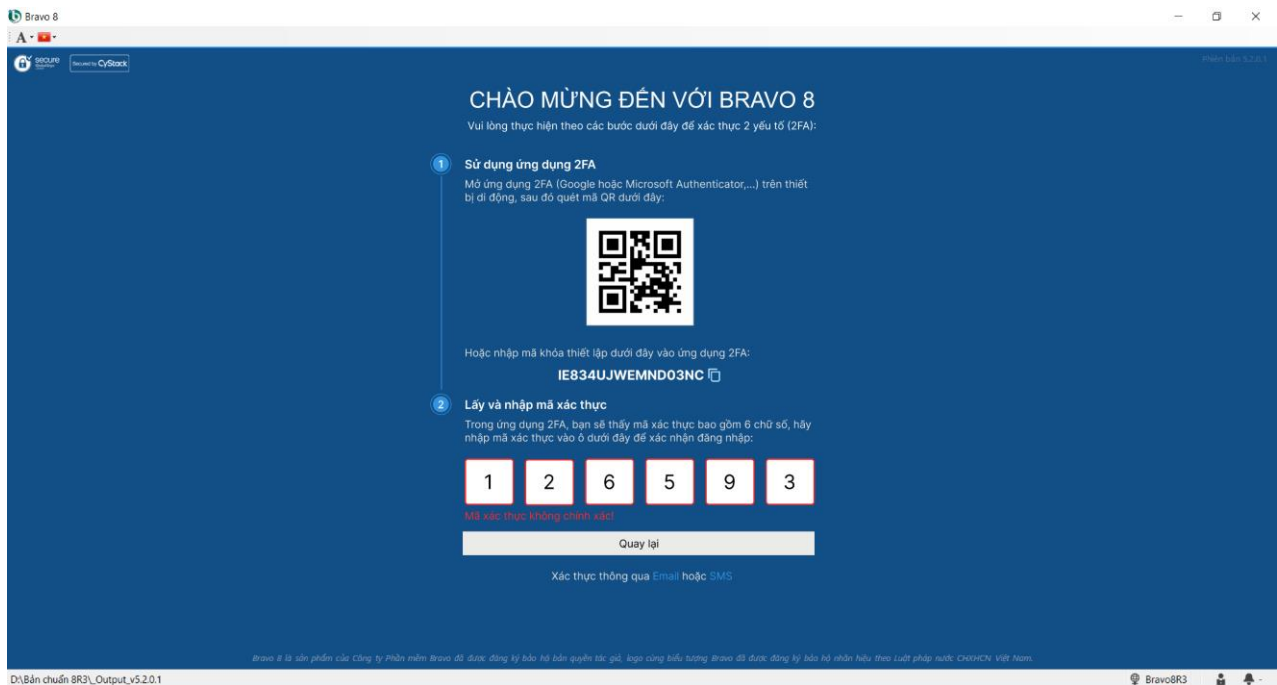
Bước 4: Người dùng nhập mã xác thực vào BravoMobile. Khi nhập đủ 6 số, chương trình sẽ tự động xác thực. Nếu mã xác thực chính xác sẽ tự động đăng nhập vào ứng dụng. Mã xác thực không chính xác sẽ hiển thị báo lỗi.



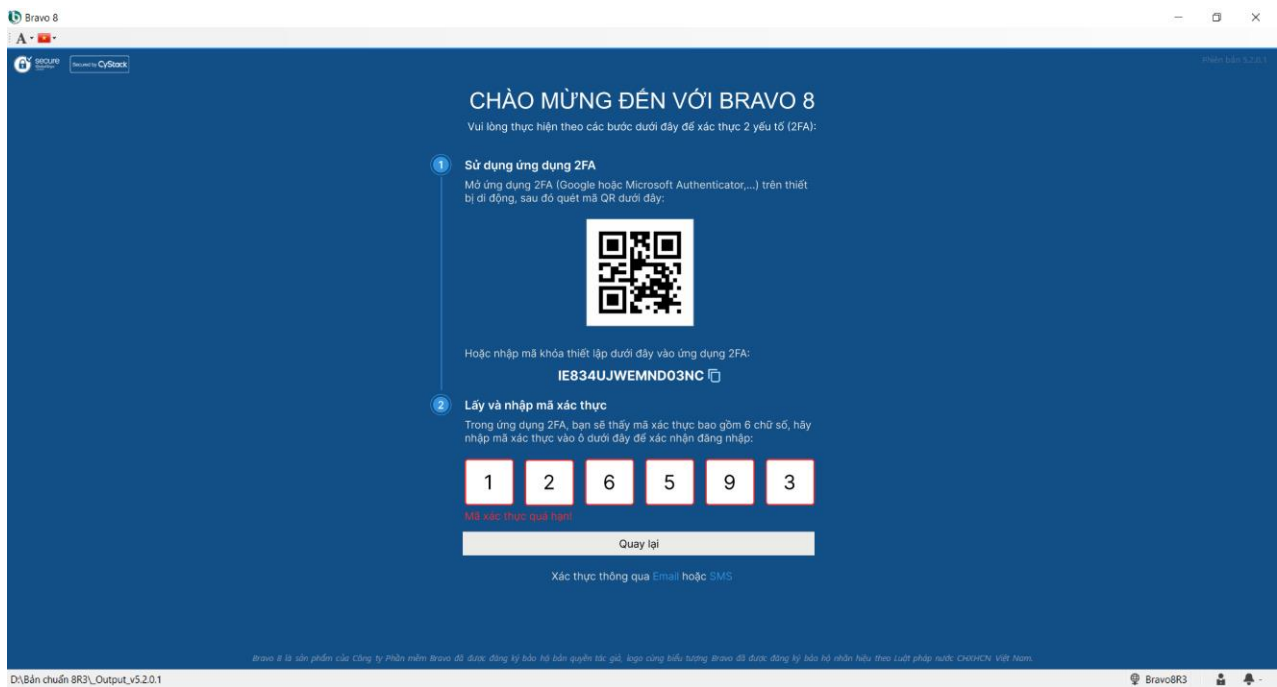
Tự động xác thực



Mã xác thực chính xác, tự động đăng nhập vào phần mềm.

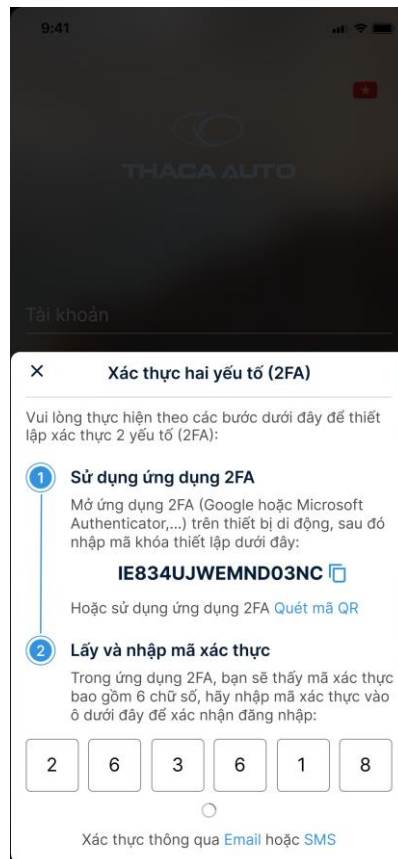


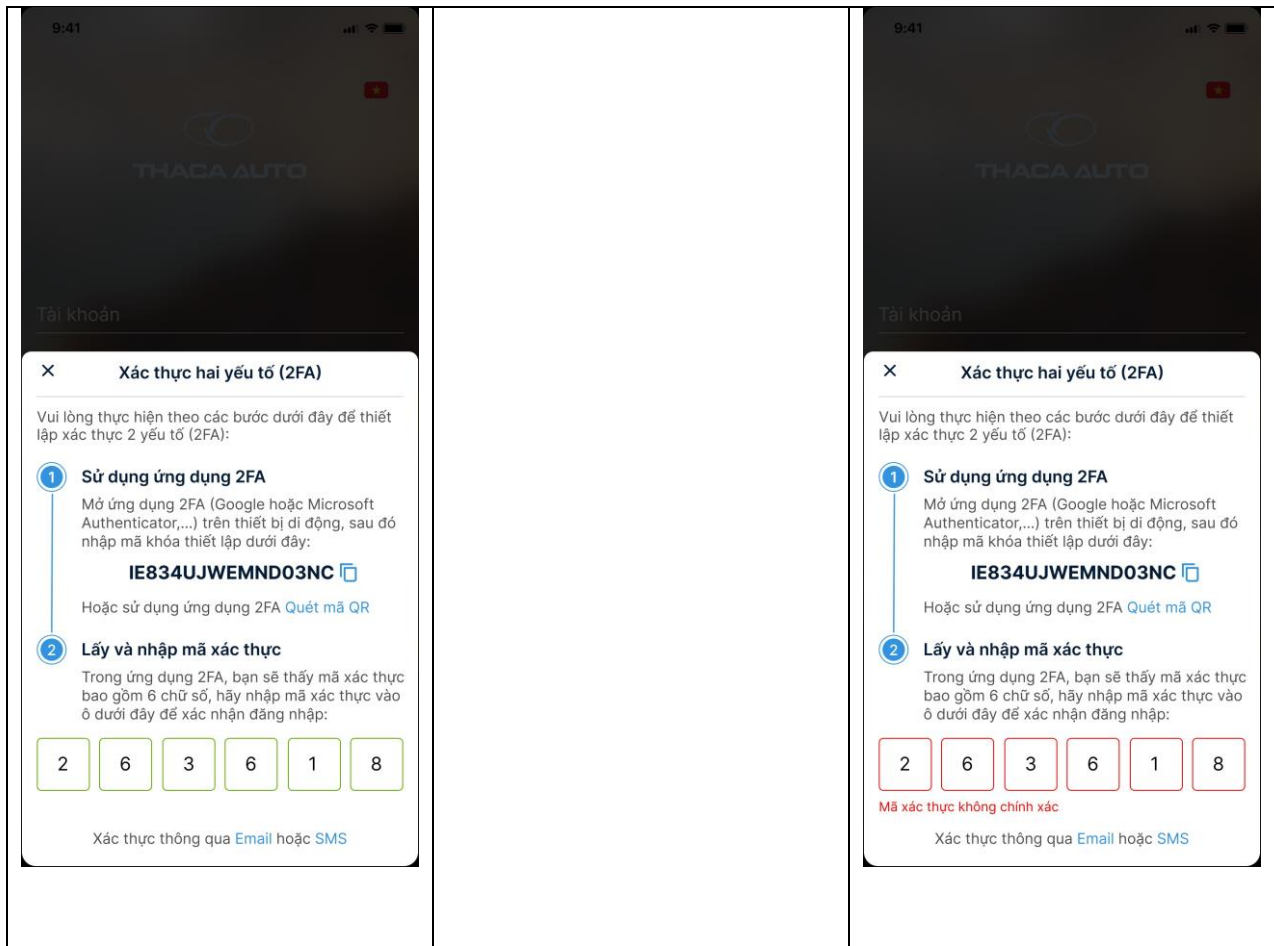
Mã xác thực không chính xác



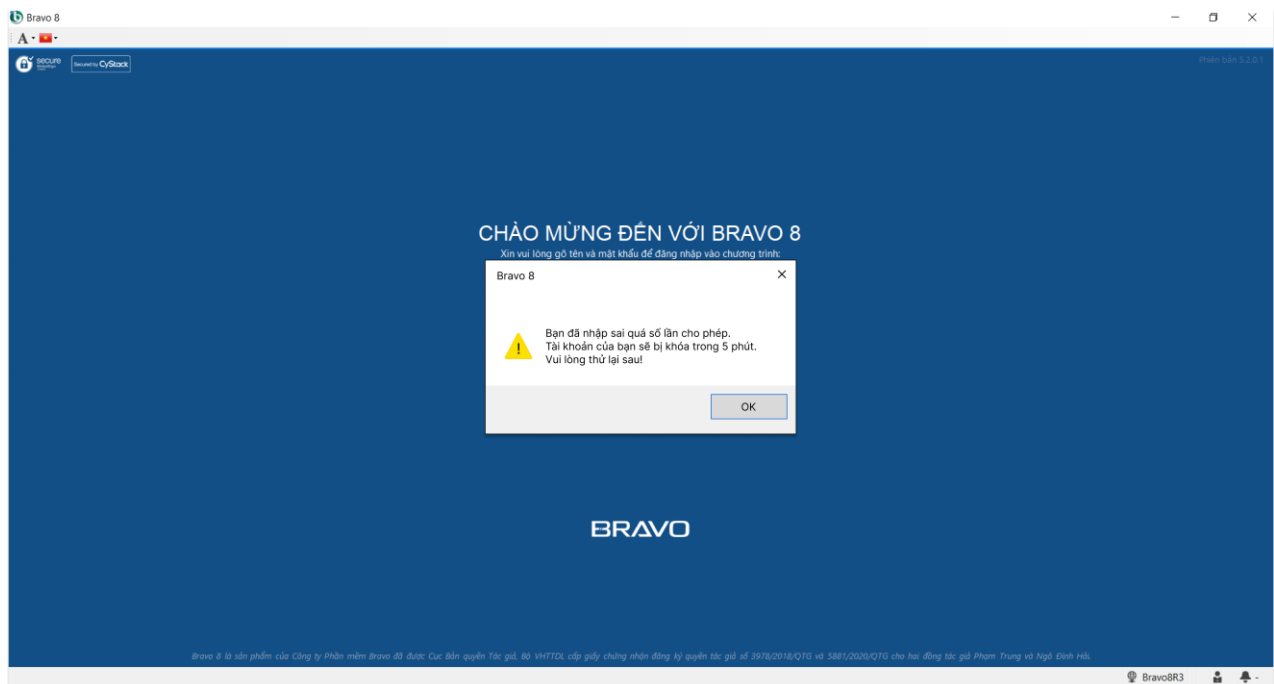
Mã xác thực quá hạn

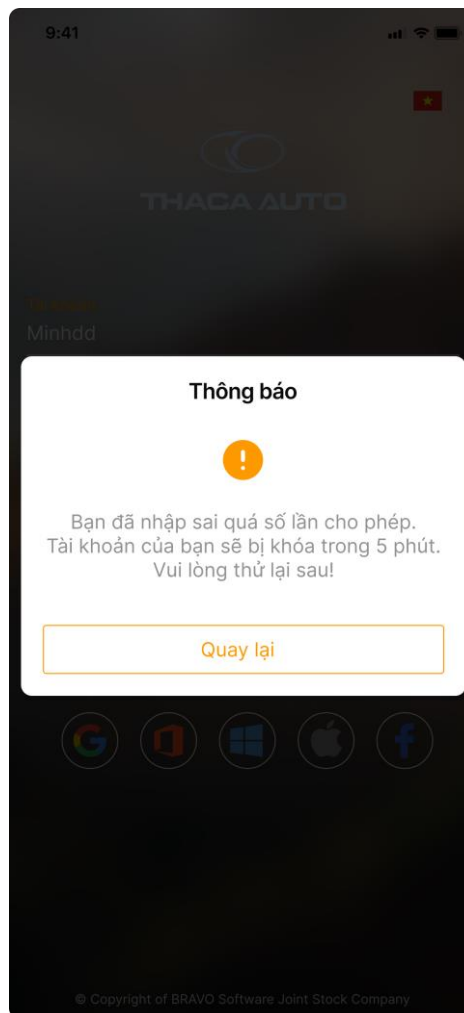
Giao diện trên Mobile:





- Trong trường hợp người dùng nhập mã sai quá 5 lần, tài khoản sẽ bị khóa trong 5 phút, chương trình sẽ tự động quay trở lại màn hình đăng nhập và hiển thị message box:





- Trong khi tài khoản đang bị khóa, nếu người dùng tiếp tục đăng nhập sẽ hiển thị MessageBox: “Tài khoản của bạn đang bị khóa. Vui lòng thử lại sau!”
- Khi đã xác thực lần đầu tiên thành công, từ những lần đăng nhập tiếp theo, Ứng dụng Authenticator sẽ tự động tạo mã xác thực, người dùng mở ứng dụng 2FA để lấy và nhập mã xác thực vào phần mềm Bravo để đăng nhập:



Giao diện WinApp/WebApp



Giao diện MobileApp

- Ngoài ra người dùng có thể lựa chọn “Xác thực thông qua [Email](#) hoặc [SMS](#)”. Chỉ hiển thị khi có những phương thức xác thực khả dụng khác. Khi lựa chọn sẽ chuyển sang màn hình xác thực thông qua Email hoặc SMS tương ứng.

4. Xác thực qua SMS/Email

- **Yêu cầu:**

- Đảm bảo có liên kết lấy được dữ liệu về Email hoặc Số điện thoại để lấy thông tin sử dụng tính năng OTP
- Giảm thiểu thao tác của quản trị viên hệ thống nhưng vẫn đảm bảo tính kịp thời và bảo mật

- **Phương án:** Sử dụng chung danh mục Quản lý người sử dụng của phiên bản Win. Tuy nhiên sẽ được thêm các phần sau :

- Danh mục quản lý người sử dụng (cung cấp thêm thông tin cho quản trị viên hệ thống xem dc thông tin email, sdt của user mà ko phải truy cập vào danh mục tương ứng:
 - + Thêm thông tin khai báo đối tượng (sử dụng cho trường hợp login mobile cho App thương hiệu).
 - + Chỉ cho nhập dữ liệu một trong 2 ô nhân viên hoặc đối tượng.
 - + Hiển thị thêm các ô email và số điện thoại trên Editor của Quản lý người sử dụng, người dùng có thể nhập liệu 2 thông tin trên.
 - + Trong trường hợp không khai báo thông tin số điện thoại/email tại Quản lý người sử dụng, chương trình sẽ truy vấn vào Danh mục nhân viên/Danh mục đối tượng để lấy ra thông tin email hoặc số điện thoại.

- Đối với các tài khoản chưa được khai báo số điện thoại/email tương ứng, khi đăng nhập phần mềm sẽ hiển thị giao diện hỗ trợ người dùng bổ sung thêm các thông tin này:

Bước 1: Người dùng nhập số điện thoại/email muốn thực hiện xác thực, sau đó ấn chọn “Gửi mã”

The image displays two screenshots of the Bravo 8 login interface, illustrating the 2FA setup process. Both screens have a blue background and a white header with the Bravo 8 logo and a 'CyStack' badge. The main heading is 'CHÀO MỪNG ĐẾN VỚI BRAVO 8'. Below the heading, a message states: 'Tài khoản của bạn chưa khai báo số điện thoại xác thực 2FA. Để xác thực đăng nhập, vui lòng thực hiện theo các bước dưới đây:'.

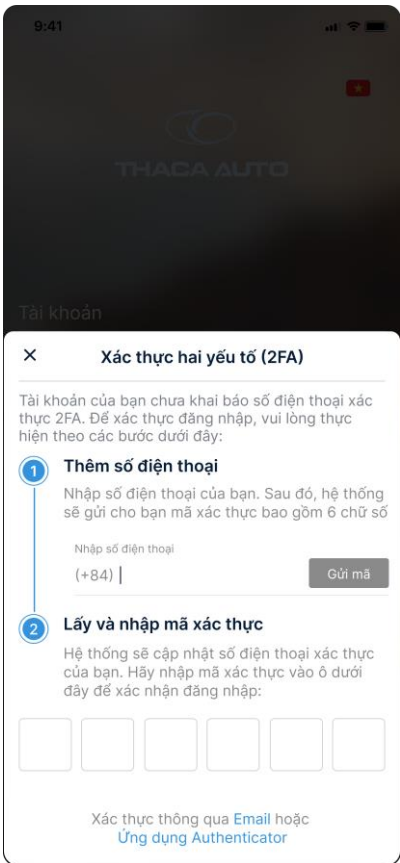
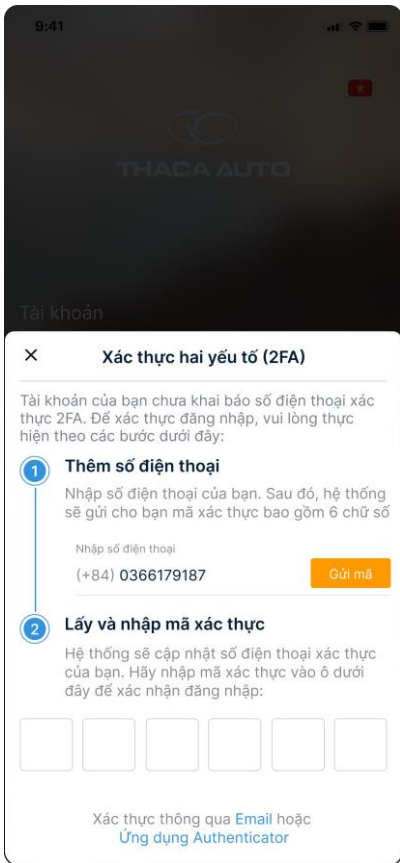
Top Screenshot (Phone Number Setup):

- 1 Thêm số điện thoại**: Nhập số điện thoại của bạn. Sau đó, hệ thống sẽ gửi cho bạn mã xác thực bao gồm 6 chữ số.
- Input field:
- Button:
- 2 Lấy và nhập mã xác thực**: Hệ thống sẽ cập nhật số điện thoại xác thực của bạn. Hãy nhập mã xác thực vào ô dưới đây để xác nhận đăng nhập.
- Input field:
- Button:
- Text: [Xác thực thông qua Email hoặc Ứng dụng Authenticator](#)

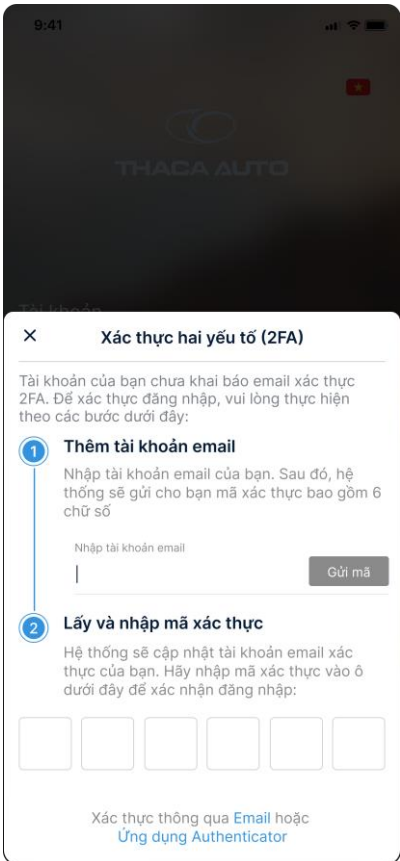
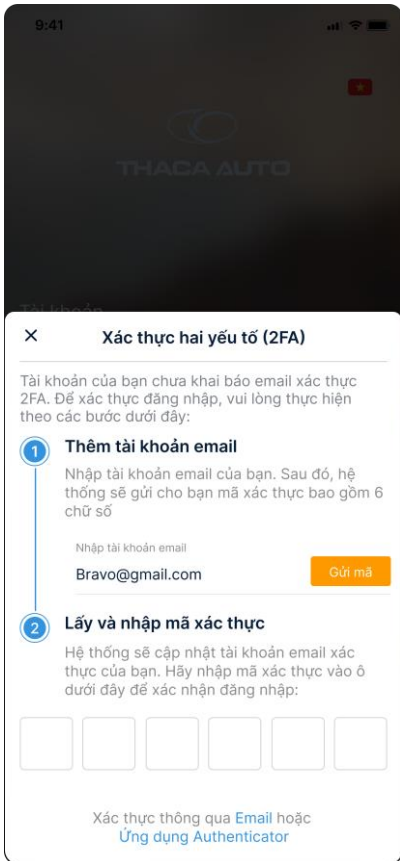
Bottom Screenshot (Email Account Setup):

- 1 Thêm tài khoản email**: Nhập tài khoản email của bạn. Sau đó, hệ thống sẽ gửi cho bạn mã xác thực bao gồm 6 chữ số.
- Input field:
- Button:
- 2 Lấy và nhập mã xác thực**: Hệ thống sẽ cập nhật tài khoản email xác thực của bạn. Hãy nhập mã xác thực vào ô dưới đây để xác nhận đăng nhập.
- Input field:
- Button:
- Text: [Xác thực thông qua SMS hoặc Ứng dụng Authenticator](#)

Bổ sung Số điện thoại/Email trên WinApp/WebApp

	
--	---

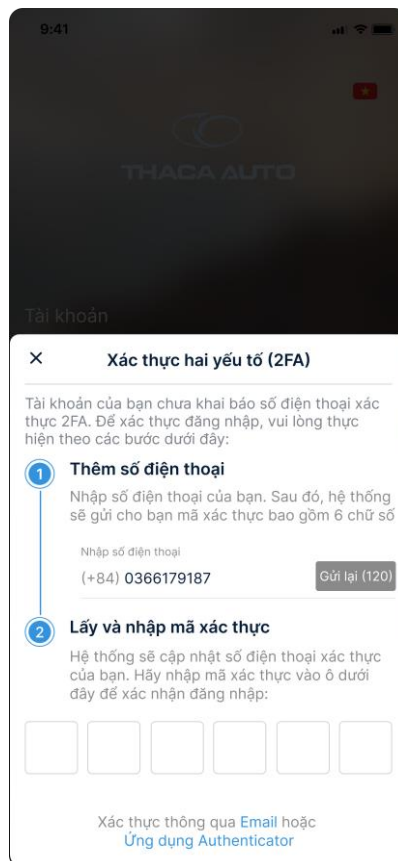
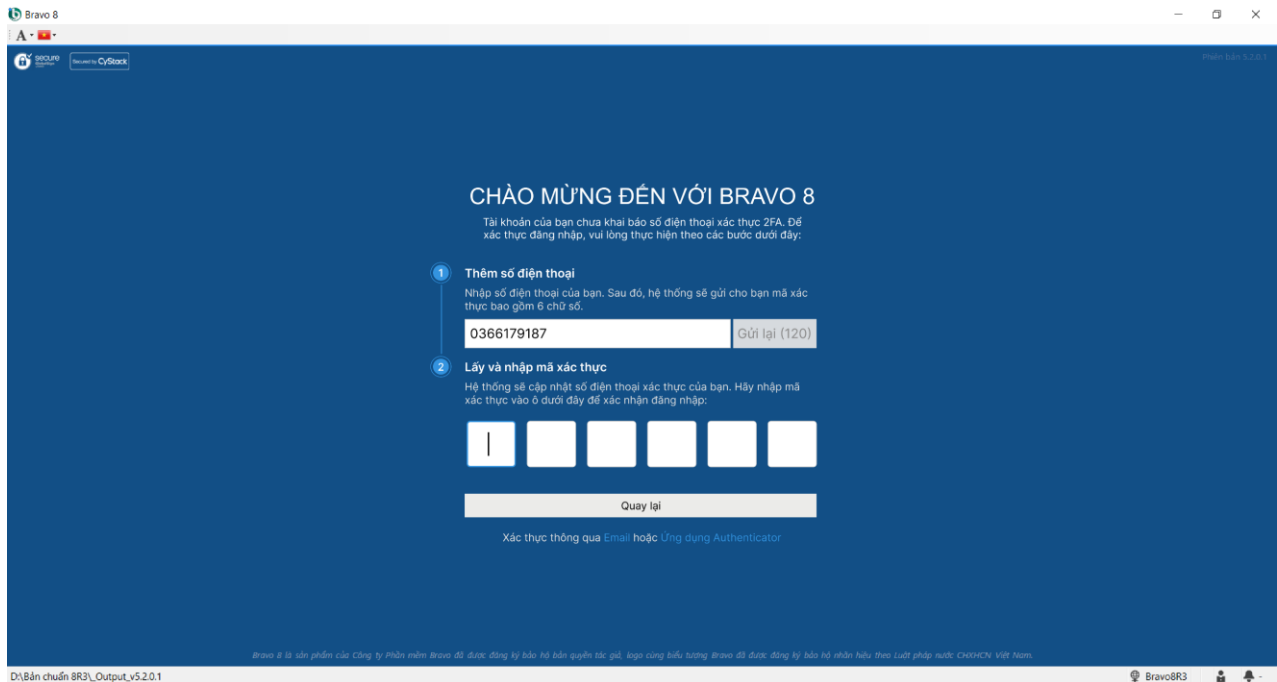
Bổ sung Số điện thoại trên Mobile App

	
---	--

Bổ sung Email trên Mobile App

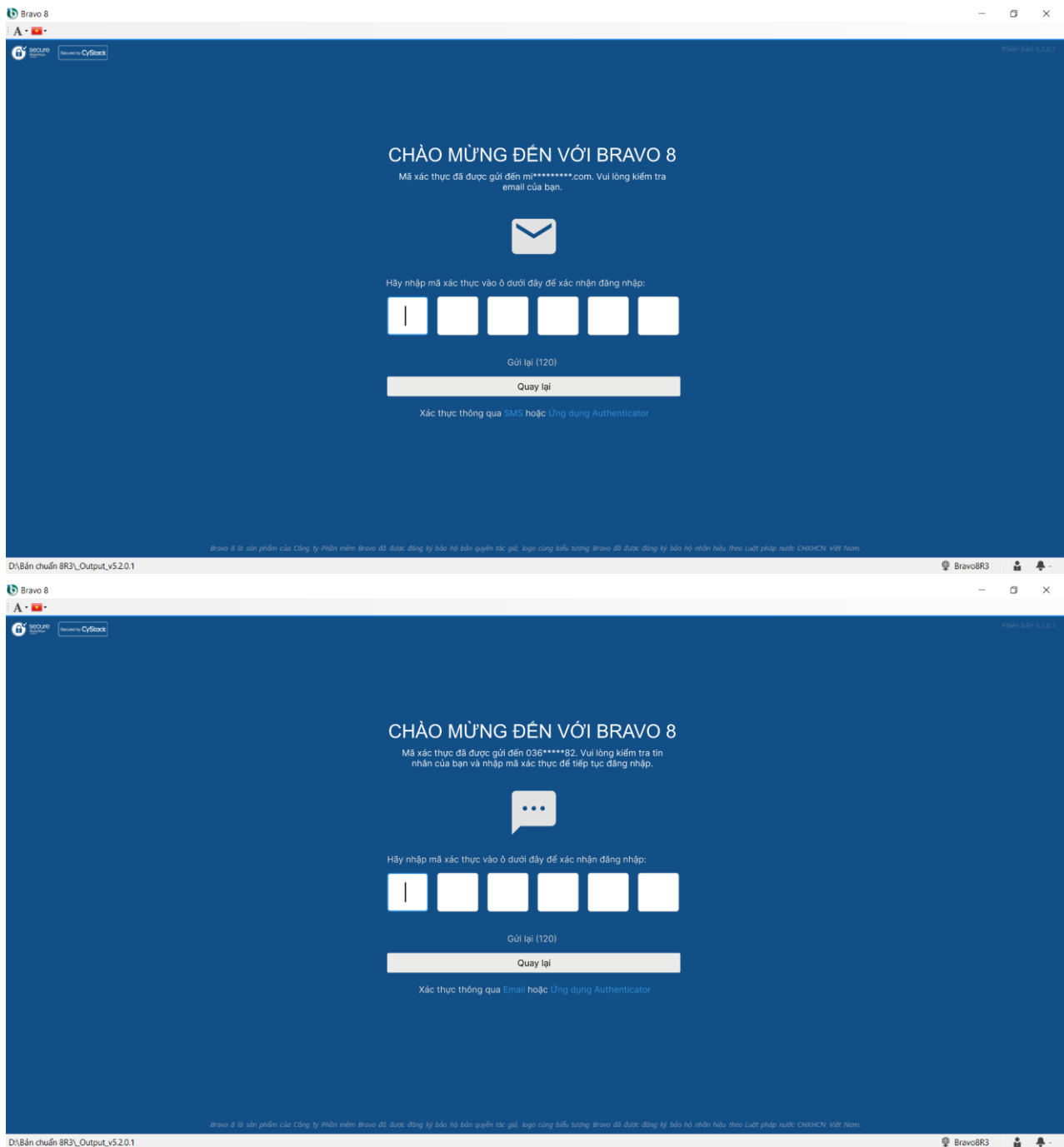
Bước 2:

- Hệ thống sẽ tạo mã xác thực và gửi đến Gmail/Số điện thoại tương ứng. Mã xác thực bao gồm 6 ký tự, không thể điều chỉnh lại. Mã xác thực sẽ có hiệu lực trong vòng 120 giây (có thể điều chỉnh lại).
- Nếu quá thời gian mã xác thực, người dùng có thể chọn chức năng “Gửi lại” để gửi lại mã xác thực.
- Người dùng sẽ cần đợi 120 giây tiếp theo để gửi lại mã xác thực.
- Chương trình sẽ hiển thị thời gian đếm ngược tại nút Gửi mã:

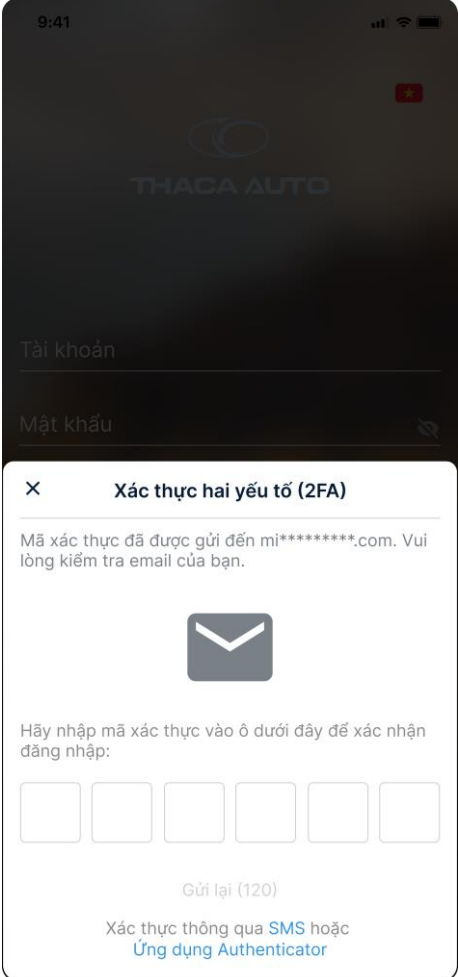
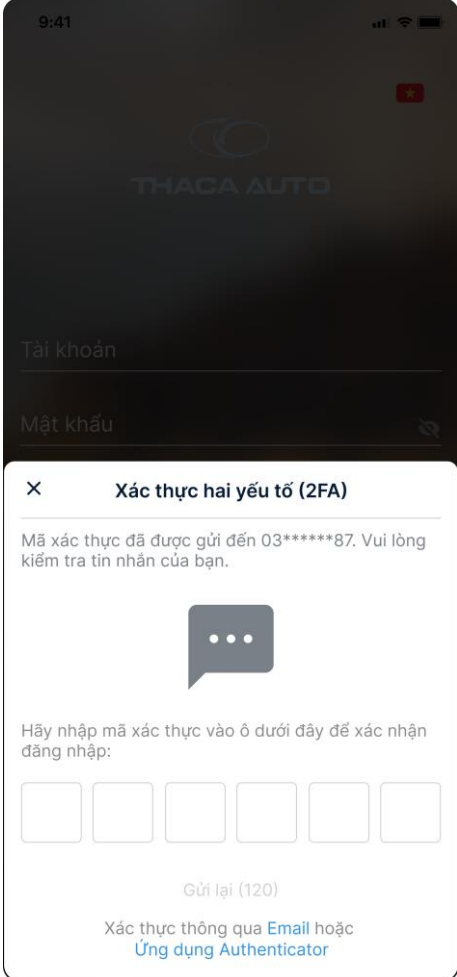


- Các thông báo sai mã xác thực/mã xác thực quá hạn/nhập sai quá số lần quy định sẽ tương tự phần mô tả của Xác thực qua ứng dụng Authenticator (đã được mô tả tại IV.2).

- Từ những lần đăng nhập tiếp theo, khi đã khai báo số điện thoại/email xác thực cho tài khoản, khi người dùng đăng nhập, phần mềm Bravo sẽ tự động gửi mã xác thực đến số điện thoại/email tương ứng. Người dùng lấy mã xác thực và nhập trên phần mềm Bravo.



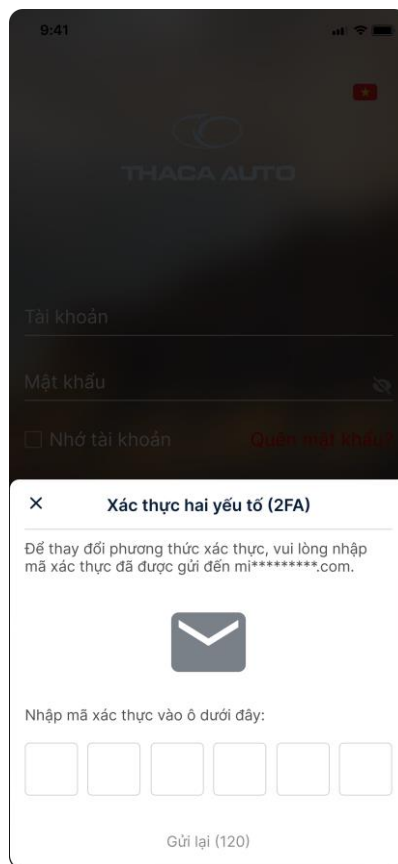
Giao diện trên WinApp/WebApp

	
Giao diện trên MobileApp	
Trong trường hợp người dùng gửi yêu cầu lấy mã OTP quá số lần cho phép, phương thức sẽ bị khóa tạm thời (có thể thiết lập số lần tối đa cho phép và thời gian cấm), khi lựa chọn Phương thức xác thực qua Email/SMS sẽ hiển thị thông báo lỗi: Thông báo  Phương thức đã bị khóa do yêu cầu vượt quá số lần cho phép. Vui lòng thử lại sau! Xác nhận	

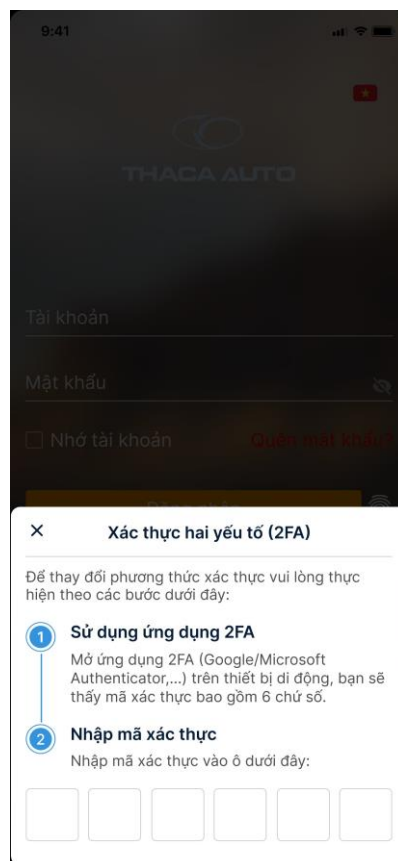
5. Một số lưu ý

Lưu ý 1

- Khi người dùng đã bật xác thực thành công qua một phương thức, trong trường hợp người dùng muốn bật xác thực qua những phương thức còn lại, người dùng cần nhập mã xác thực của phương thức cũ trước khi chuyển đổi.
- **Ví dụ:** Người dùng đang sử dụng xác thực qua Email, nếu muốn chuyển sang phương thức xác thực qua Ứng dụng Authenticator, người dùng sẽ cần phải nhập mã xác thực được gửi đến email trước khi thay đổi. Giao diện sẽ hiển thị như sau:



- + Khi người dùng xác thực thành công, chương trình sẽ hiển thị giao diện xác thực qua Ứng dụng Authenticator.
- + Sau khi đã kích hoạt lần đầu thành công, từ những lần thay đổi phương thức xác thực tiếp theo sẽ không cần nhập mã từ phương thức cũ.
- Tương tự, đối với hình thức xác thực qua Email hoặc SMS, khi tài khoản chưa khai báo Email/Số điện thoại thì sẽ được coi là chưa kích hoạt phương thức này. Người dùng cần nhập mã xác thực từ phương thức cũ để tiến hành khai báo Email/Số điện thoại xác thực cho tài khoản.



Lưu ý 2

Trong trường hợp user đang sử dụng phương thức xác thực 2FA nhưng có sự thay đổi hệ thống dẫn đến phương thức xác thực của người dùng không còn khả dụng, hệ thống sẽ xử lý như sau:

Ví dụ: Người dùng đang sử dụng phương thức xác thực AuthApp:

- + Quản trị hệ thống thiết lập chỉ còn 2 phương thức xác thực qua Email và SMS, khi người dùng đăng nhập, chương trình sẽ hiển thị thông báo hỗ trợ người dùng chọn lại phương thức xác thực mới.
- + Nếu Quản trị hệ thống thiết lập chỉ còn 1 phương thức xác thực, chương trình sẽ tự động thiết lập phương thức này cho người dùng.

Lưu ý 3

- Các thông báo lỗi tại WinApp/WebApp có thể xử lý hiển thị tại vị trí khác theo cơ chế của nền tảng, không nhất thiết xử lý hiển thị tại phía dưới phần nhập mã xác thực.

Lưu ý 4

- Trong quá trình xác thực hai yếu tố, nếu người dùng ấn nút “Quay lại”, chương trình sẽ quay lại màn hình đăng nhập và giữ nguyên thông tin tài khoản và mật khẩu đã nhập.